Vulnerability Assessment & Penetration Test Report

AI-assisted, lab-only assessment. Findings are grounded in tool evidence.

1. Executive Summary

15 consolidated findings were identified (1 critical, 1 high, 6 medium, 2 low, 5 info). Highest priority: VAPT-001 CVE-2011-2523 reported for ftp vsftpd 2.3.4 on 192.168.56.101:21; VAPT-002 SQL Injection on 192.168.56.101:80; VAPT-003 X-Frame-Options Header Not Set on 192.168.56.101:80.

Scope: 192.168.56.0/24 | Exclusions: 192.168.56.1 | Exposure assumption: internal

Analyst request: test

2. Assessment Methodology

Approach follows NIST SP 800-115 phases (discovery, scanning, analysis, reporting) and references OWASP Top 10, CVE, CVSS, CWE. This does not claim formal compliance with any standard.

Rules of engagement: lab targets only; scope checked before every action; active validation needs explicit human approval.

Tool execution summary

Tool	Port	Mode	Status	Note
nmap	-	import	success	imported sample (synthetic); 9 findings
nikto	80	import	success	imported sample (synthetic); 4 findings
zap	80	import	success	imported sample (synthetic) (ZAP is import-only); 4 findings

Integration status

Tool	Status	Notes
Nmap	Live + Import	Requires nmap binary for live mode
Nikto	Live + Import	Requires nikto binary for live mode
OWASP ZAP	Import-only	ZAP JSON report import; live API not implemented
Nessus	Unsupported	Commercial licence required; not integrated
OpenVAS / Greenbone	Planned	GMP API adapter planned
Burp Suite	Unsupported	Commercial; analyst-assisted only, not integrated
Metasploit	Planned (approval gate only)	Approval workflow exists; NO exploit is executed

3. Severity Distribution & Prioritised Findings

critical: 1; high: 1; medium: 6; low: 2; info: 5

ID	Title	Asset	Sev	Risk	Status
VAPT-001	CVE-2011-2523 reported for ftp vsftpd 2.3.4	192.168.56.101:21	critical	8.3	suspected
VAPT-002	SQL Injection	192.168.56.101:80	high	5.6	suspected

VAPT-003	X-Frame-Options Header Not Set	192.168.56.101:80	medium	5.5	confirmed
VAPT-004	Directory indexing found.	192.168.56.101:80	medium	5.5	confirmed
VAPT-005	Legacy/risky service exposed: FTP (cleartext crede	192.168.56.101:21	medium	4.7	suspected
VAPT-006	Legacy/risky service exposed: Telnet (cleartext re	192.168.56.101:23	medium	4.7	suspected
VAPT-007	Legacy/risky service exposed: MySQL exposed to net	192.168.56.101:3306	medium	4.7	suspected
VAPT-008	Apache/2.2.8 appears to be outdated (current is at	192.168.56.101:80	medium	3.8	suspected
VAPT-009	Cookie No HttpOnly Flag	192.168.56.101:80	low	2.5	suspected
VAPT-010	The X-Content-Type-Options header is not set.	192.168.56.101:80	low	2.1	suspected
VAPT-011	Open port 21/tcp (ftp)	192.168.56.101:21	info	0.5	confirmed
VAPT-012	Open port 22/tcp (ssh)	192.168.56.101:22	info	0.5	confirmed
VAPT-013	Open port 23/tcp (telnet)	192.168.56.101:23	info	0.5	confirmed
VAPT-014	Open port 80/tcp (http)	192.168.56.101:80	info	0.5	confirmed
VAPT-015	Open port 3306/tcp (mysql)	192.168.56.101:3306	info	0.5	confirmed

Risk score = (CVSS or severity base) x exposure x asset impact x confidence weight, capped at 10.

4. Detailed Vulnerability Findings

VAPT-001 - CVE-2011-2523 reported for ftp vsftpd 2.3.4

Asset: 192.168.56.101:21 | Severity: critical | CVSS: 9.8 | Risk: 8.3

CVE: CVE-2011-2523 | CWE: n/a | Confidence: medium | Status: suspected | Validation: not validated

Type: observed | Reported by: nmap

Description: Nmap script 'vulners' reported CVE-2011-2523.

Evidence:

[nmap] vsftpd 2.3.4: CVE-2011-2523 9.8 https://vulners.com/cve/CVE-2011-2523 (ref: nmap_sample.xml#192.168.56.101:21/tcp, 2026-11-02T04:50:16+00:00)

VAPT-002 - SQL Injection

Asset: 192.168.56.101:80 | Severity: high | CVSS: n/a | Risk: 5.6

CVE: n/a | CWE: CWE-89 | Confidence: low | Status: suspected | Validation: not validated

Type: observed | Reported by: zap

Description: Possible SQL injection in parameter id.

Evidence:

[zap] GET http://192.168.56.101/product.php?id=1 param=id evidence=You have an error in your SQL syntax (ref: zap_sample.json#pluginid=40018, 2026-11-02T04:50:16+00:00)

VAPT-003 - X-Frame-Options Header Not Set

Asset: 192.168.56.101:80 | Severity: medium | CVSS: n/a | Risk: 5.5

CVE: n/a | CWE: CWE-1021 | Confidence: high | Status: confirmed | Validation: not validated

Type: observed | Reported by: nikto, zap

Description: Missing anti-clickjacking header.

Evidence:

[zap] GET http://192.168.56.101/ param=x-frame-options evidence= (ref: zap_sample.json#pluginid=10020, 2026-11-02T04:50:16+00:00)

[nikto] GET / -> The anti-clickjacking X-Frame-Options header is not present. (ref: nikto_sample.json#id=999957, 2026-11-02T04:50:16+00:00)

VAPT-004 - Directory indexing found.

Asset: 192.168.56.101:80 | Severity: medium | CVSS: n/a | Risk: 5.5

CVE: n/a | CWE: CWE-548 | Confidence: high | Status: confirmed | Validation: not validated

Type: observed | Reported by: nikto, zap

Description: Directory indexing found.

Evidence:

[nikto] GET /icons/ -> Directory indexing found. (ref: nikto_sample.json#id=000366, 2026-11-02T04:50:16+00:00)

[zap] GET http://192.168.56.101/icons/ param= evidence=Index of /icons (ref: zap_sample.json#pluginid=0, 2026-11-02T04:50:16+00:00)

VAPT-005 - Legacy/risky service exposed: FTP (cleartext credentials)

Asset: 192.168.56.101:21 | Severity: medium | CVSS: n/a | Risk: 4.7

CVE: n/a | CWE: n/a | Confidence: medium | Status: suspected | Validation: not validated

Type: inferred (rule-based) | Reported by: nmap

Description: Rule-based inference: FTP (cleartext credentials) is reachable.

Evidence:

[nmap] open port 21 service=ftp (ref: nmap_sample.xml#192.168.56.101:21/tcp, 2026-11-02T04:50:16+00:00)

VAPT-006 - Legacy/risky service exposed: Telnet (cleartext remote shell)

Asset: 192.168.56.101:23 | Severity: medium | CVSS: n/a | Risk: 4.7

CVE: n/a | CWE: n/a | Confidence: medium | Status: suspected | Validation: not validated

Type: inferred (rule-based) | Reported by: nmap

Description: Rule-based inference: Telnet (cleartext remote shell) is reachable.

Evidence:

[nmap] open port 23 service=telnet (ref: nmap_sample.xml#192.168.56.101:23/tcp, 2026-11-02T04:50:16+00:00)

VAPT-007 - Legacy/risky service exposed: MySQL exposed to network

Asset: 192.168.56.101:3306 | Severity: medium | CVSS: n/a | Risk: 4.7

CVE: n/a | CWE: n/a | Confidence: medium | Status: suspected | Validation: not validated

Type: inferred (rule-based) | Reported by: nmap

Description: Rule-based inference: MySQL exposed to network is reachable.

Evidence:

[nmap] open port 3306 service=mysql (ref: nmap_sample.xml#192.168.56.101:3306/tcp, 2026-11-02T04:50:16+00:00)

VAPT-008 - Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.x).

Asset: 192.168.56.101:80 | Severity: medium | CVSS: n/a | Risk: 3.8

CVE: n/a | CWE: n/a | Confidence: low | Status: suspected | Validation: not validated

Type: observed | Reported by: nikto

Description: Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.x).

Evidence:

[nikto] GET / -> Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.x). (ref: nikto_sample.json#id=000013, 2026-11-02T04:50:16+00:00)

VAPT-009 - Cookie No HttpOnly Flag

Asset: 192.168.56.101:80 | Severity: low | CVSS: n/a | Risk: 2.5

CVE: n/a | CWE: CWE-1004 | Confidence: medium | Status: suspected | Validation: not validated

Type: observed | Reported by: zap

Description: Cookie set without HttpOnly.

Evidence:

[zap] GET http://192.168.56.101/login.php param=PHPSESSID evidence=Set-Cookie: PHPSESSID (ref: zap_sample.json#pluginid=10010, 2026-11-02T04:50:16+00:00)

VAPT-010 - The X-Content-Type-Options header is not set.

Asset: 192.168.56.101:80 | Severity: low | CVSS: n/a | Risk: 2.1

CVE: n/a | CWE: n/a | Confidence: low | Status: suspected | Validation: not validated

Type: observed | Reported by: nikto

Description: The X-Content-Type-Options header is not set.

Evidence:

[nikto] GET / -> The X-Content-Type-Options header is not set. (ref: nikto_sample.json#id=999102, 2026-11-02T04:50:16+00:00)

VAPT-011 - Open port 21/tcp (ftp)

Asset: 192.168.56.101:21 | Severity: info | CVSS: n/a | Risk: 0.5

CVE: n/a | CWE: n/a | Confidence: high | Status: confirmed | Validation: not validated

Type: observed | Reported by: nmap

Description: Port 21/tcp is open running ftp vsftpd 2.3.4.

Evidence:

[nmap] state=open service=ftp banner='vsftpd 2.3.4' (ref: nmap_sample.xml#192.168.56.101:21/tcp, 2026-11-02T04:50:16+00:00)

VAPT-012 - Open port 22/tcp (ssh)

Asset: 192.168.56.101:22 | Severity: info | CVSS: n/a | Risk: 0.5

CVE: n/a | CWE: n/a | Confidence: high | Status: confirmed | Validation: not validated

Type: observed | Reported by: nmap

Description: Port 22/tcp is open running ssh OpenSSH 4.7p1.

Evidence:

[nmap] state=open service=ssh banner='OpenSSH 4.7p1' (ref: nmap_sample.xml#192.168.56.101:22/tcp, 2026-11-02T04:50:16+00:00)

VAPT-013 - Open port 23/tcp (telnet)

Asset: 192.168.56.101:23 | Severity: info | CVSS: n/a | Risk: 0.5

CVE: n/a | CWE: n/a | Confidence: high | Status: confirmed | Validation: not validated

Type: observed | Reported by: nmap

Description: Port 23/tcp is open running telnet Linux telnetd.

Evidence:

[nmap] state=open service=telnet banner='Linux telnetd' (ref: nmap_sample.xml#192.168.56.101:23/tcp, 2026-11-02T04:50:16+00:00)

VAPT-014 - Open port 80/tcp (http)

Asset: 192.168.56.101:80 | Severity: info | CVSS: n/a | Risk: 0.5

CVE: n/a | CWE: n/a | Confidence: high | Status: confirmed | Validation: not validated

Type: observed | Reported by: nmap

Description: Port 80/tcp is open running http Apache httpd 2.2.8.

Evidence:

[nmap] state=open service=http banner='Apache httpd 2.2.8' (ref: nmap_sample.xml#192.168.56.101:80/tcp, 2026-11-02T04:50:16+00:00)

VAPT-015 - Open port 3306/tcp (mysql)

Asset: 192.168.56.101:3306 | Severity: info | CVSS: n/a | Risk: 0.5

CVE: n/a | CWE: n/a | Confidence: high | Status: confirmed | Validation: not validated

Type: observed | Reported by: nmap

Description: Port 3306/tcp is open running mysql MySQL 5.0.51a.

Evidence:

[nmap] state=open service=mysql banner='MySQL 5.0.51a' (ref: nmap_sample.xml#192.168.56.101:3306/tcp, 2026-11-02T04:50:16+00:00)

5. Impact and Remediation

VAPT-001: CVE-2011-2523 reported for ftp vsftpd 2.3.4

Impact: known vulnerability (CVE-2011-2523). Fix: upgrade/patch the affected component and verify the version.

VAPT-002: SQL Injection

Impact: data theft/modification. Fix: parameterised queries, input validation, least-privilege DB account.

VAPT-003: X-Frame-Options Header Not Set

Impact: UI redress/clickjacking. Fix: send 'X-Frame-Options: DENY' or CSP frame-ancestors.

VAPT-004: Directory indexing found.

Impact: information disclosure. Fix: disable directory indexing (Options -Indexes).

VAPT-005: Legacy/risky service exposed: FTP (cleartext credentials)

Impact: cleartext/legacy service increases attack surface. Fix: disable or replace with encrypted alternative; restrict by firewall.

VAPT-006: Legacy/risky service exposed: Telnet (cleartext remote shell)

Impact: cleartext/legacy service increases attack surface. Fix: disable or replace with encrypted alternative; restrict by firewall.

VAPT-007: Legacy/risky service exposed: MySQL exposed to network

Impact: data theft/modification. Fix: parameterised queries, input validation, least-privilege DB account.

VAPT-008: Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.x).

Impact: unpatched known issues likely. Fix: upgrade to a supported version.

VAPT-009: Cookie No HttpOnly Flag

Impact: session theft via XSS. Fix: set HttpOnly (and Secure) on session cookies.

VAPT-010: The X-Content-Type-Options header is not set.

Review and apply vendor hardening guidance.

References: OWASP Top 10, NIST SP 800-115, MITRE CVE/CWE, vendor advisories.

6. Assessment Limitations

Results depend on tool coverage and (if imported) recorded outputs. Findings marked 'suspected' are not validated. No exploitation was performed by this agent. Scan failures are listed in the tool execution table.

Human approvals

No active validation requested or approved.